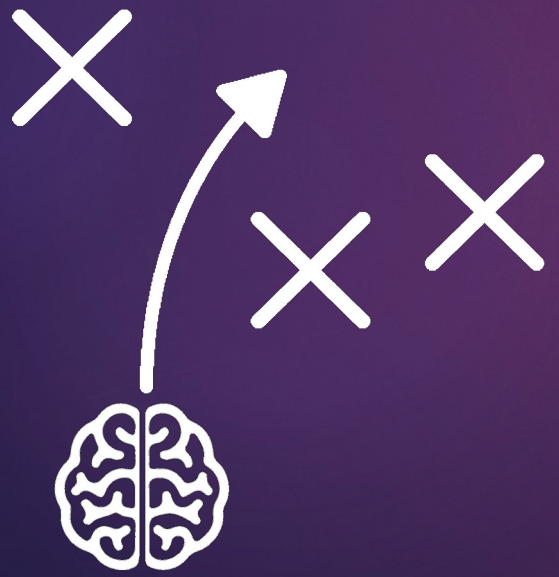
A Standard For Investigative Playbooks



Matthew Gracie
Security Onion Solutions
BSides Chicago 2025

Who Am I And What Am I Talking About?

Playbook Principles

- In any given investigation, analysts ask investigative questions that they answer with data (evidence) to determine what happened and if malicious activity occurred.
- Analysts encounter common scenarios (cues) across diverse investigations based on the evidence they encounter and their forecasting of potentially related events.
- Many of the initial investigative questions analysts will ask in response to these cues can be predicted.
- If you can predict the questions analysts will ask in an investigation, providing the analyst with a list of those questions when they encounter the cue has significant performance benefits.

Source: https://chrissanders.org/2025/06/human-centered-playbooks/

Example Scenario

You receive an alert in your SOC that an endpoint belonging to a user in your Accounting department launched a cURL process. What do you need to know?

What is the parent process?

Does the user have admin rights?

Have they run cURL before?

What was the URL they were downloading from?

What was the file type they were retrieving?

Does Virustotal have a record of that hash?

Playbook Components

- Plain-language investigative questions.
- Context explaining why the question matters.
- Appropriate data and log sources for answering the question.
- Relative time ranges for pertinent evidence.
- Search queries tailored to the analyst’s tools.

Demonstration

Playbooks as a Training Aid

- Using a Playbook during an investigation helps junior analysts learn by doing.
- Codifying knowledge into Playbooks helps scale senior analyst experience across multiple teams so others can benefit.
- The act of writing a new Playbook forces reflection and careful evaluation of assumptions and investigative techniques.

This standard isn't just a framework for guiding analysis, it's a tool for building better analysts.

Questions?

@infosecgoon

infosecgoon@roadflares.org

https://www.github.com/infosecgoon